Benemérita Universidad Autónoma de Puebla
Facultad de Ciencias de la Computación

Materia: Intercomunicación y Seguridad en Redes

Nombre del alumno: Miguel Angel De La Cruz Espinosa y Jorge del Moral Muñoz
Matrícula: 202118754

Práctica de Laboratorio
Detección y Mitigación de Rootkits en Linux

Objetivos

Al finalizar la práctica el alumno:

1. Comprenderá qué es un rootkit y cómo afecta al sistema.
2. Identificará indicadores de compromiso (IoC).
3. Utilizará herramientas de detección en Linux.
4. Analizará resultados técnicos.
5. Aplicará medidas de mitigación y fortalecimiento del sistema

Consideraciones Éticas

- Esta práctica debe realizarse únicamente en una **máquina virtual aislada**.
- No se deben instalar rootkits reales en sistemas productivos.
- El objetivo es **detección y análisis defensivo**.

Requisitos de Trabajo

- Distribución Linux
- Máquina Virtual (VirtualBox / VMware)
- Herramientas:
  - rkhunter
  - chkrootkit
  - lynis
  - auditd

Parte 1: Marco Teórico Breve

Un rootkit es un conjunto de herramientas diseñadas para mantener acceso privilegiado oculto, evadir mecanismos de detección, modificar procesos, archivos o llamadas al sistema.

Tipos principales:

- User-space rootkits
- Kernel rootkits
- Bootkits
- Firmware rootkits

Parte 2: Preparación de laboratorio de pruebas

1.Actualizar sistema

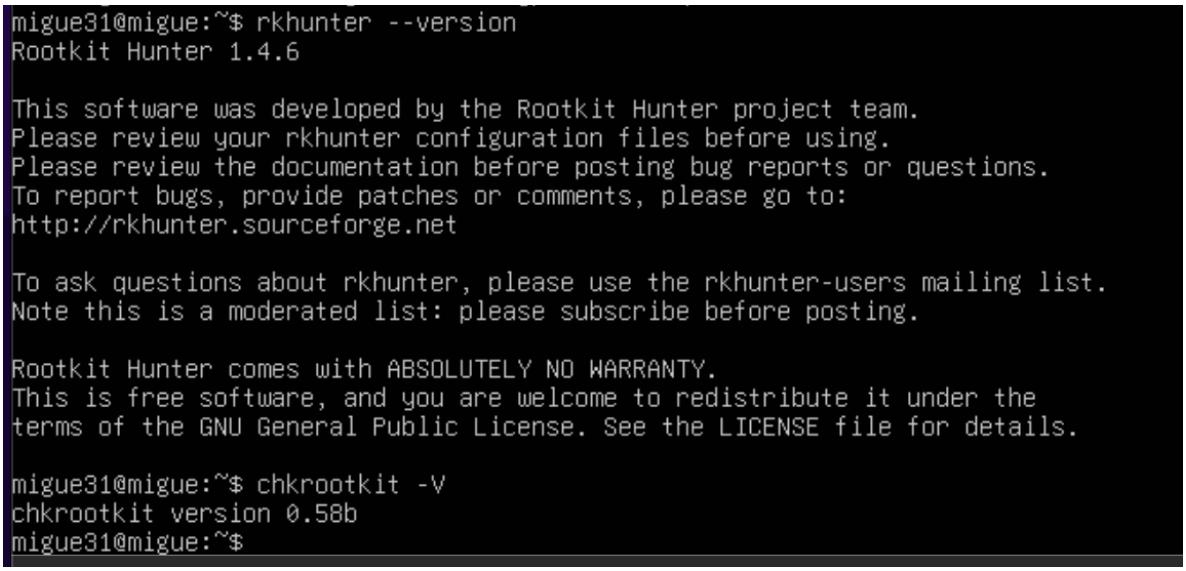
```
sudo apt update && sudo apt upgrade -y
```

2.Instalar herramientas de detección

```
sudo apt install rkhunter chkrootkit lynis auditd -y
```

Verificar instalación:

```
rkhunter --version
chkrootkit -V
```



Parte 3: Simulación

En lugar de instalar malware, simularemos comportamientos sospechosos.

1. **Crear usuario oculto sospechoso**

```
sudo useradd -M -s /bin/bash backdooruser
```

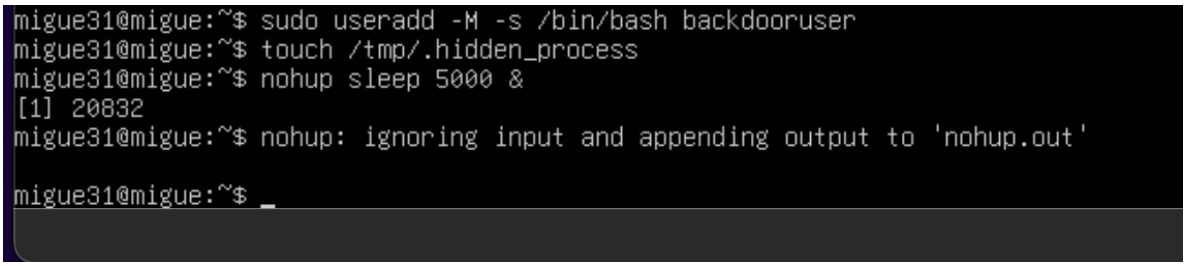
Modificar UID manualmente (simulación avanzada opcional).

2. **Crear archivo oculto en /tmp**

```
touch /tmp/.hidden_process
```

3. **Crear proceso en segundo plano**

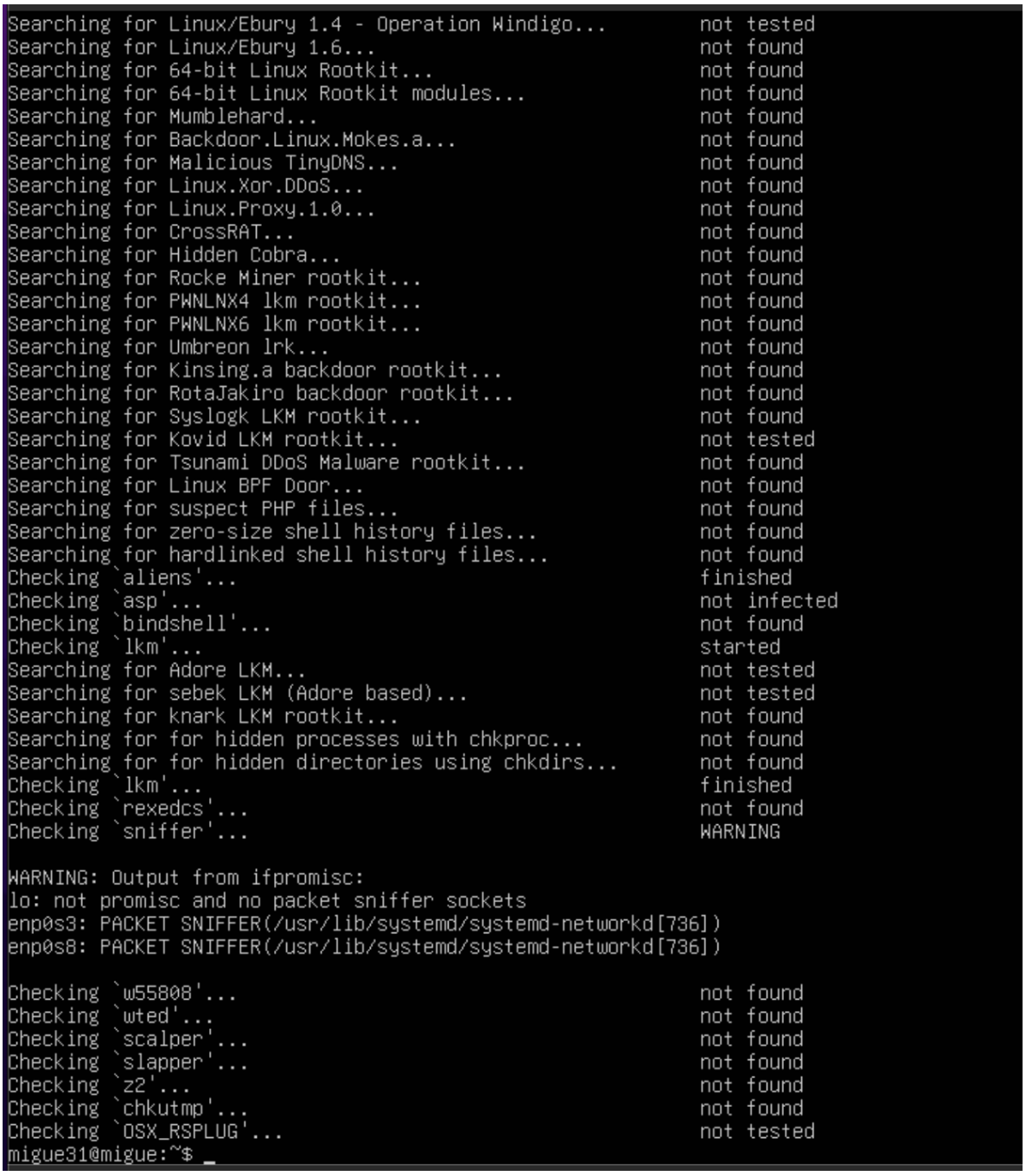
```
nohup sleep 5000 &
```



Parte 4: Detección

4. **Ejecutar chkrootkit**

```
sudo chkrootkit
```



Responda las siguientes preguntas:

- ¿Qué pruebas se pueden realizar con la herramienta?
- **Verificación de binarios:** Compara ejecutables críticos (como `ls`, `ps` y `netstat`) para detectar modificaciones maliciosas.
- **Detección de firmas:** Busca patrones de texto y archivos conocidos asociados a rootkits de espacio de usuario.

- **Revisión de interfaces:** Identifica si alguna interfaz de red está en modo promiscuo (posible sniffing).

- **Análisis de archivos de sistema:** Examina archivos como `lastlog` y `wtmp` en busca de intentos por borrar rastros de conexiones.

- **Búsqueda de archivos ocultos:** Localiza directorios o procesos que intentan esconderse de las herramientas estándar del sistema.

- ¿Qué significa “not infected”? Indica que, tras comparar las firmas y comportamientos, no se encontró evidencia de los rootkits específicos que la herramienta tiene en su base de datos.

- ¿Hubo falsos positivos? No se encontro ninguno solo unos warnings

5. **Ejecutar rkhunter**

Actualizar base:

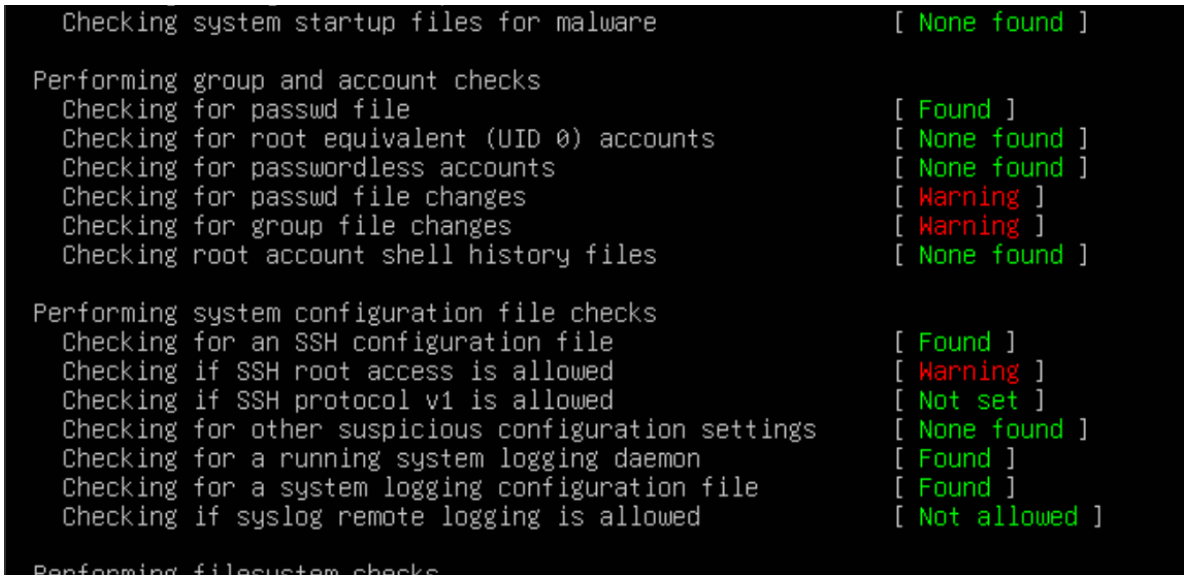
```
sudo rkhunter --update
```

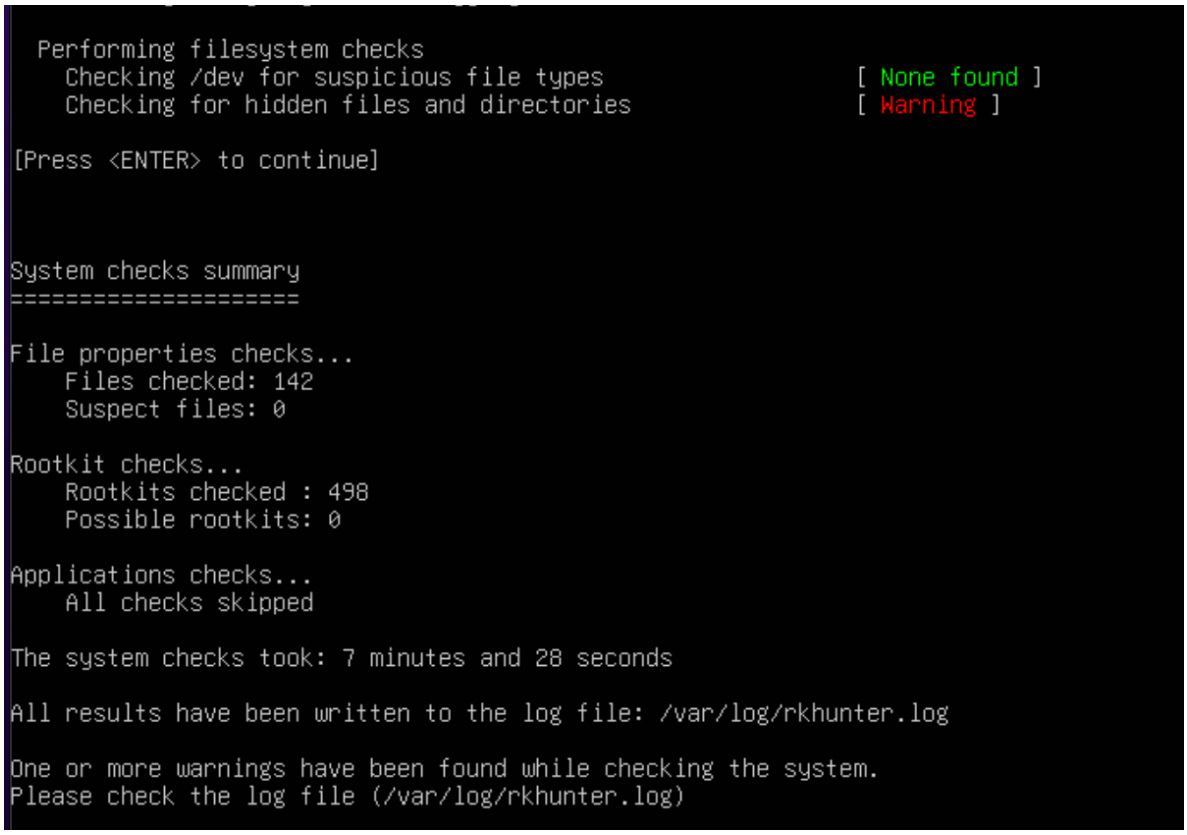
Ejecutar análisis:

```
sudo rkhunter --check
```

Analizar:

- Advertencias encontradas
- Archivos modificados
- Cambios en hashes



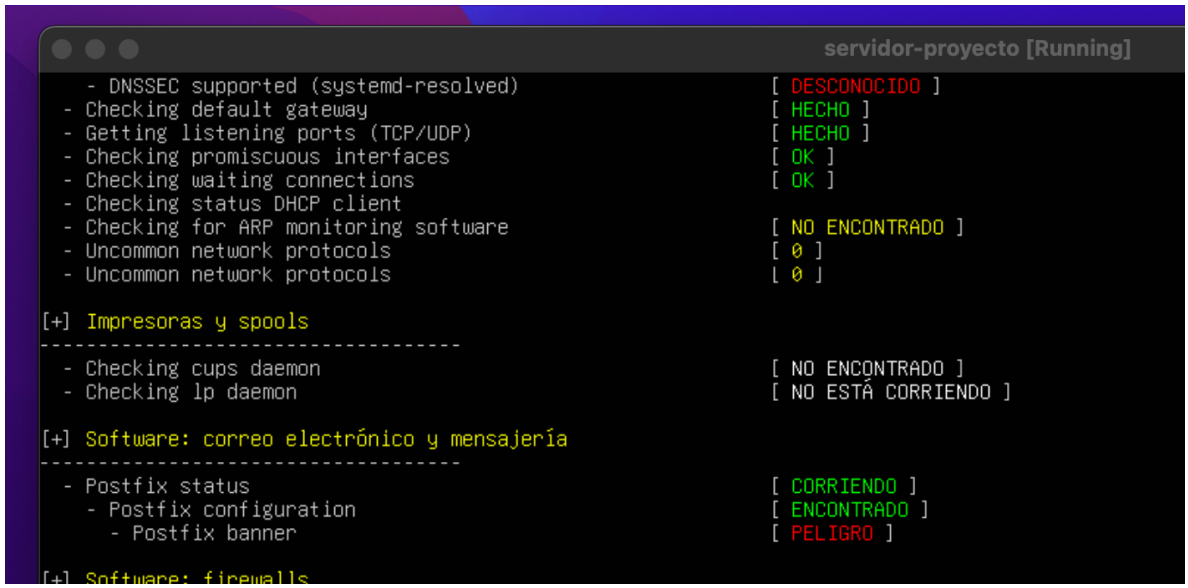

Performing filesystem checks
Checking /dev for suspicious file types [None found]
Checking for hidden files and directories [Warning]
[Press <ENTER> to continue]
System checks summary
File properties checks...
Files checked: 142
Suspect files: 0
Rootkit checks...
Rootkits checked : 498
Possible rootkits: 0
Applications checks...
All checks skipped
The system checks took: 7 minutes and 28 seconds
All results have been written to the log file: /var/log/rkhunter.log
One or more warnings have been found while checking the system.
Please check the log file (/var/log/rkhunter.log)

6. Auditoría con Lynis

```
sudo lynis audit system
```

Identificar:





```
[+] Bastionado del kernel
------------------------------------
  - Comparing sysctl key pairs with scan profile
    - dev.tty.ldisc_autoload (exp: 0)                         [ DIFERENTE ]
    - fs.protected_fifos (exp: 2)                             [ DIFERENTE ]
    - fs.protected_hardlinks (exp: 1)                         [ OK ]
    - fs.protected_regular (exp: 2)                           [ OK ]
    - fs.protected_symlinks (exp: 1)                          [ OK ]
    - fs.suid_dumpable (exp: 0)                               [ DIFERENTE ]
    - kernel.core_uses_pid (exp: 1)                           [ DIFERENTE ]
    - kernel.ctrl-alt-del (exp: 0)                            [ OK ]
    - kernel.dmesg_restrict (exp: 1)                          [ OK ]
    - kernel.kptr_restrict (exp: 2)                           [ DIFERENTE ]
    - kernel.modules_disabled (exp: 1)                        [ DIFERENTE ]
    - kernel.perf_event_paranoid (exp: 3)                     [ DIFERENTE ]
    - kernel.randomize_va_space (exp: 2)                      [ OK ]
    - kernel.sysrq (exp: 0)                                   [ DIFERENTE ]
    - kernel.unprivileged_bpf_disabled (exp: 1)               [ DIFERENTE ]
    - kernel.yama.ptrace_scope (exp: 1 2 3)                   [ OK ]
    - net.core.bpf_jit_harden (exp: 2)                        [ DIFERENTE ]
    - net.ipv4.conf.all.accept_redirects (exp: 0)             [ OK ]
    - net.ipv4.conf.all.accept_source_route (exp: 0)          [ OK ]
    - net.ipv4.conf.all.bootp_relay (exp: 0)                  [ OK ]
    - net.ipv4.conf.all.forwarding (exp: 0)                   [ OK ]
    - net.ipv4.conf.all.log_martians (exp: 1)                 [ DIFERENTE ]
    - net.ipv4.conf.all.mc_forwarding (exp: 0)                [ OK ]
    - net.ipv4.conf.all.proxy_arp (exp: 0)                    [ OK ]
    - net.ipv4.conf.all.rp_filter (exp: 1)                    [ DIFERENTE ]
    - net.ipv4.conf.all.send_redirects (exp: 0)               [ DIFERENTE ]
    - net.ipv4.conf.default.accept_redirects (exp: 0)         [ OK ]
    - net.ipv4.conf.default.accept_source_route (exp: 0)      [ DIFERENTE ]
    - net.ipv4.conf.default.log_martians (exp: 1)             [ DIFERENTE ]
    - net.ipv4.icmp_echo_ignore_broadcasts (exp: 1)           [ OK ]
    - net.ipv4.icmp_ignore_bogus_error_responses (exp: 1)     [ OK ]
```

```
================================================================================

  [TIP]: Enhance Lynis audits by adding your settings to custom.prf (see /etc/lynis/default.prf for all settings)

migue31@migue:~$ _
```

```
================================================================================

  Lynis security scan details:

  Hardening index : 63 [#############        ]
  Tests performed : 264
  Plugins enabled : 1

  Components:
  - Firewall               [V]
  - Malware scanner        [V]

  Scan mode:
  Normal [V]  Forensics [ ]  Integration [ ]  Pentest [ ]

  Lynis modules:
  - Compliance status      [?]
  - Security audit         [V]
  - Vulnerability scan     [V]

  Files:
  - Test and debug information      : /var/log/lynis.log
  - Report data                     : /var/log/lynis-report.dat

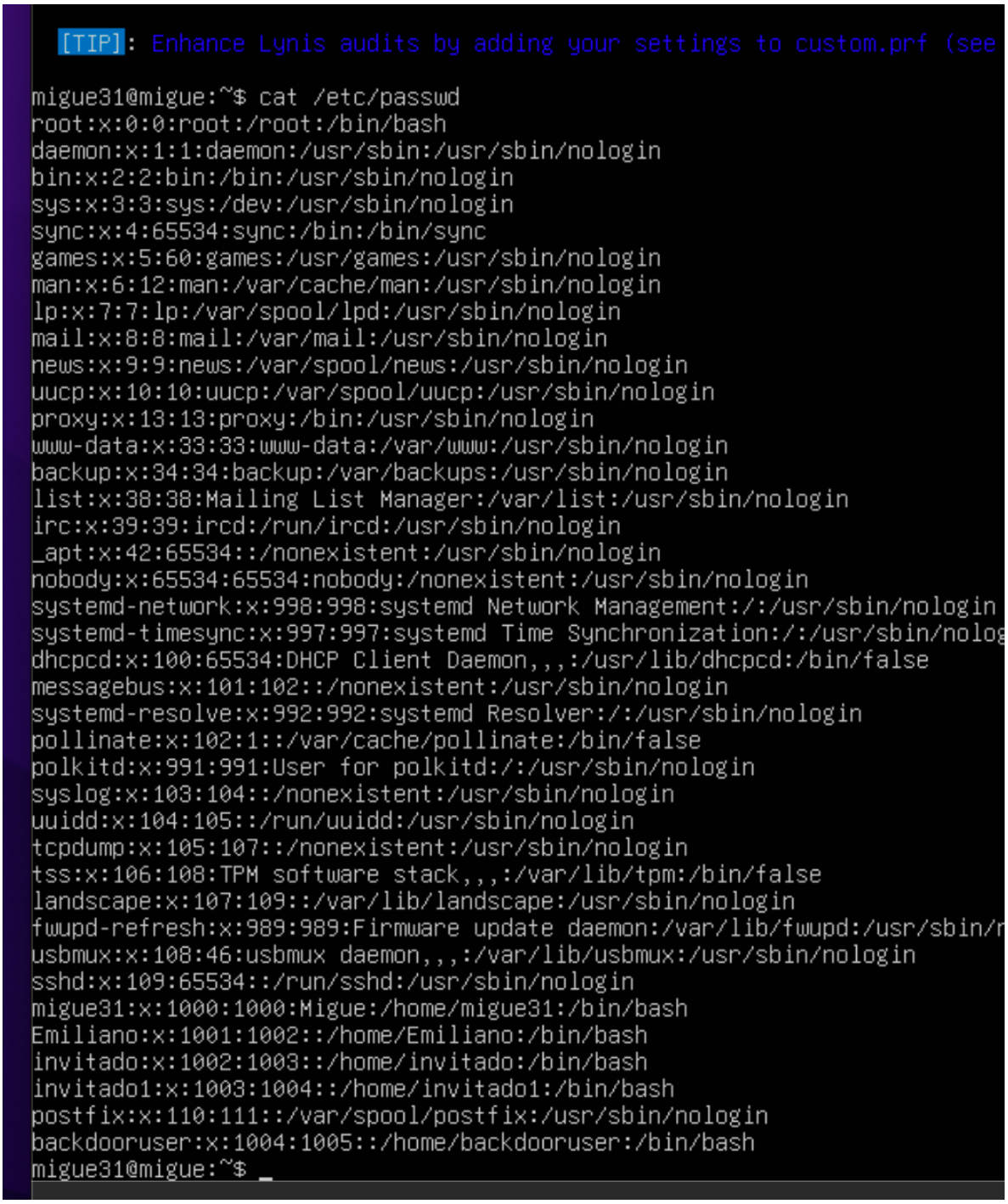
================================================================================
```

- Recomendaciones de hardening
- Riesgos detectados
- Puntuación del sistema

Parte 5: Análisis Forense Básico

1. Revisar usuarios del sistema:

```
cat /etc/passwd
```



2. Listar procesos:

```
ps aux
```

```
USER         PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root           1  0.4  0.6  22760 13868 ?        Ss   16:17   0:09 /sbin/init
root           2  0.0  0.0      0     0 ?        S    16:17   0:00 [kthreadd]
root           3  0.0  0.0      0     0 ?        S    16:17   0:00 [pool_workqueue_release]
root           4  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-rcu_g]
root           5  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-rcu_p]
root           6  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-slub_]
root           7  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-netns]
root          12  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-mm_pe]
root          13  0.0  0.0      0     0 ?        I    16:17   0:00 [rcu_tasks_kthread]
root          14  0.0  0.0      0     0 ?        I    16:17   0:00 [rcu_tasks_rude_kthread]
root          15  0.0  0.0      0     0 ?        I    16:17   0:00 [rcu_tasks_trace_kthread]
root          16  0.3  0.0      0     0 ?        S    16:17   0:07 [ksoftirqd/0]
root          17  0.1  0.0      0     0 ?        I    16:17   0:04 [rcu_preempt]
root          18  0.0  0.0      0     0 ?        S    16:17   0:00 [migration/0]
root          19  0.0  0.0      0     0 ?        S    16:17   0:00 [idle_inject/0]
root          20  0.0  0.0      0     0 ?        S    16:17   0:00 [cpuhp/0]
root          21  0.0  0.0      0     0 ?        S    16:17   0:00 [kdevtmpfs]
root          22  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-inet_]
root          23  0.0  0.0      0     0 ?        S    16:17   0:00 [kauditd]
root          24  0.0  0.0      0     0 ?        S    16:17   0:00 [khungtaskd]
root          25  0.0  0.0      0     0 ?        I    16:17   0:00 [kworker/u2:1-events_unbound]
root          26  0.0  0.0      0     0 ?        S    16:17   0:00 [oom_reaper]
root          28  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-write]
root          29  0.0  0.0      0     0 ?        S    16:17   0:00 [kcompactd0]
root          30  0.0  0.0      0     0 ?        SN   16:17   0:00 [ksmd]
root          31  0.0  0.0      0     0 ?        SN   16:17   0:00 [khugepaged]
root          32  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-kinte]
root          33  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-kbloc]
root          34  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-blkcg]
root          35  0.0  0.0      0     0 ?        S    16:17   0:00 [irq/9-acpi]
root          36  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-tpm_d]
root          37  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-ata_s]
root          38  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-md]
root          39  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-md_bi]
root          40  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-edac-]
root          41  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-devfr]
root          42  0.0  0.0      0     0 ?        S    16:17   0:00 [watchdogd]
root          43  0.0  0.0      0     0 ?        I<   16:17   0:01 [kworker/0:1H-kblockd]
root          44  0.0  0.0      0     0 ?        S    16:17   0:00 [kswapd0]
root          45  0.0  0.0      0     0 ?        S    16:17   0:00 [ecryptfs-kthread]
root          46  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-kthro]
root          47  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-acpi_]
root          48  0.0  0.0      0     0 ?        S    16:17   0:00 [scsi_eh_0]
root          49  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-scsi_]
root          50  0.0  0.0      0     0 ?        S    16:17   0:00 [scsi_eh_1]
root          51  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-scsi_]
root          53  0.0  0.0      0     0 ?        I    16:17   0:01 [kworker/u2:4-flush-252:1]
root          55  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-mld]
:_
```

```
root         363  0.0  1.3 289116 27452 ?        SLsl 16:17   0:00 /sbin/multipathd -d -s
root         381  0.0  0.3  29200  7932 ?        Ss   16:17   0:00 /usr/lib/systemd/systemd-udevd
root         388  0.0  0.0      0     0 ?        S    16:17   0:00 [psimon]
root         454  0.0  0.0      0     0 ?        S    16:17   0:00 [jbd2/dm-0-8]
root         455  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-ext4-]
root         491  0.0  0.0      0     0 ?        S    16:17   0:00 [irq/18-vmwgfx]
root         495  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-ttm]
root         523  0.0  0.0      0     0 ?        S    16:17   0:00 [jbd2/sda2-8]
root         524  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-ext4-]
systemd+     600  0.0  0.6  21584 13204 ?        Ss   16:17   0:00 /usr/lib/systemd/systemd-resolved
systemd+     612  0.0  0.3  91028  7952 ?        Ssl  16:17   0:00 /usr/lib/systemd/systemd-timesyncd
systemd+     736  0.0  0.4  19020  9548 ?        Ss   16:17   0:00 /usr/lib/systemd/systemd-networkd
root         750  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-cfg80]
message+     782  0.0  0.2   9796  5480 ?        Ss   16:17   0:00 @dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-
nly
polkitd      787  0.0  0.4 308164  8108 ?        Ssl  16:17   0:00 /usr/lib/polkit-1/polkitd --no-debug
root         792  0.0  0.4  18000  8848 ?        Ss   16:17   0:00 /usr/lib/systemd/systemd-logind
root         793  0.0  0.6 469088 13768 ?        Ssl  16:17   0:00 /usr/libexec/udisks2/udisksd
root         822  0.0  1.1 109604 23164 ?        Ssl  16:17   0:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signa
root         841  0.0  0.6 392032 13076 ?        Ssl  16:17   0:00 /usr/sbin/ModemManager
root         843  0.0  0.1   6824  2904 ?        Ss   16:17   0:00 /usr/sbin/cron -f -P
root         859  0.0  0.4  12024  8216 ?        Ss   16:17   0:00 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
root         866  0.0  0.2   6944  4868 tty1     Ss   16:17   0:00 /bin/login -p --
migue31     1077  0.0  0.5  20380 11488 ?        Ss   16:17   0:00 /usr/lib/systemd/systemd --user
migue31     1078  0.0  0.1  21156  3592 ?        S    16:17   0:00 (sd-pam)
migue31     1090  0.0  0.3  10364  6752 tty1     S    16:17   0:00 -bash
root        1132  0.0  0.0      0     0 ?        I<   16:17   0:00 [kworker/R-tls-s]
root        2116  0.0  0.1  12908  3260 ?        S<sl 16:20   0:00 /sbin/auditd
root        2413  0.0  0.0      0     0 ?        S    16:20   0:00 [psimon]
root        2732  0.0  0.2  42852  4916 ?        Ss   16:20   0:00 /usr/lib/postfix/sbin/master -w
postfix     2733  0.0  0.3  43304  7948 ?        S    16:20   0:00 pickup -l -t unix -u -c
postfix     2734  0.0  0.3  43344  8024 ?        S    16:20   0:00 qmgr -l -t unix -u
postfix     9213  0.0  0.4  43404  8076 ?        S    16:21   0:00 cleanup -z -t unix -u -c
postfix     9216  0.0  0.3  43312  7908 ?        S    16:21   0:00 trivial-rewrite -n rewrite -t unix -u -c
postfix     9222  0.0  0.4  42924  8716 ?        S    16:21   0:00 local -t unix
syslog     11703  0.0  0.2 222508  5516 ?        Ssl  16:21   0:00 /usr/sbin/rsyslogd -n -iNONE
migue31    20832  0.0  0.1   5604  2108 tty1     S    16:28   0:00 sleep 5000
root       23000  0.7  0.0      0     0 ?        I    16:36   0:07 [kworker/0:0-cgroup_destroy]
root       23001  0.0  0.0      0     0 ?        I    16:36   0:00 [kworker/u2:0-events_unbound]
root       47290  0.0  0.0      0     0 ?        I<   16:41   0:00 [kworker/0:2H-kblockd]
root      107577  0.0  0.0      0     0 ?        I    16:45   0:00 [kworker/u2:2-events_power_efficient]
root      138061  1.2  0.0      0     0 ?        I    16:46   0:05 [kworker/0:1-events]
root      159576  2.3  0.0      0     0 ?        I    16:50   0:06 [kworker/0:2-events]
root      163770  0.0  0.0      0     0 ?        I<   16:50   0:00 [kworker/0:0H-kblockd]
root      170868  0.0  1.0 372596 21040 ?        Ssl  16:50   0:00 /usr/libexec/packagekitd
root      173609  0.0  0.0      0     0 ?        I    16:51   0:00 [kworker/u2:3-flush-252:1]
root      173615  0.0  0.0      0     0 ?        I    16:51   0:00 [kworker/u2:5-events_unbound]
migue31   189819  100  0.2  10884  4580 tty1     R+   16:54   0:00 ps aux
migue31   189820  0.0  0.1   6072  2648 tty1     S+   16:54   0:00 less
(END)
```

3. Buscar archivos ocultos:

```
ls -la /tmp
```

```
migue31@migue:~$ ls -la /tmp
total 48
drwxrwxrwt 12 root    root    4096 feb 20 16:52 .
drwxr-xr-x 23 root    root    4096 feb 20 16:50 ..
drwxrwxrwt  2 root    root    4096 feb 20 16:15 .font-unix
-rw-rw-r--  1 migue31 migue31    0 feb 20 16:28 .hidden_process
drwxrwxrwt  2 root    root    4096 feb 20 16:15 .ICE-unix
drwx------  2 root    root    4096 feb 20 16:15 snap-private-tmp
drwx------  3 root    root    4096 feb 20 16:16 systemd-private-592fd9ec99704b99a6023a66b8c650aa-ModemManager.service-SzC8fZ
drwx------  3 root    root    4096 feb 20 16:16 systemd-private-592fd9ec99704b99a6023a66b8c650aa-polkit.service-kowqRN
drwx------  3 root    root    4096 feb 20 16:16 systemd-private-592fd9ec99704b99a6023a66b8c650aa-systemd-logind.service-VWjPs2
drwx------  3 root    root    4096 feb 20 16:15 systemd-private-592fd9ec99704b99a6023a66b8c650aa-systemd-resolved.service-lyMkcW
drwx------  3 root    root    4096 feb 20 16:15 systemd-private-592fd9ec99704b99a6023a66b8c650aa-systemd-timesyncd.service-2ECsd5
drwxrwxrwt  2 root    root    4096 feb 20 16:15 .X11-unix
drwxrwxrwt  2 root    root    4096 feb 20 16:15 .XIM-unix
```

4. Revisar logs:

```
sudo journalctl -xe
```

```
feb 20 16:55:16 migue kernel: workqueue: e1000_watchdog [e1000] hogged CPU for >13333us 32 times, consider switching to WQ_UNBOUND
feb 20 16:55:55 migue PackageKit[170868]: daemon quit
feb 20 16:55:55 migue systemd[1]: packagekit.service: Deactivated successfully.
    Subject: Unit succeeded
    Defined-By: systemd
    Support: http://www.ubuntu.com/support

    The unit packagekit.service has successfully entered the 'dead' state.
feb 20 16:56:01 migue CRON[189836]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
feb 20 16:56:01 migue CRON[189837]: (root) CMD (/usr/local/bin/backup_diario.sh)
feb 20 16:56:01 migue root[189842]: respaldo de sistema completado: respaldo_datos_2026-02-20_16-56.tar.gz
feb 20 16:56:01 migue postfix/pickup[2733]: 8EBE150: uid=0 from=<root>
feb 20 16:56:01 migue CRON[189836]: pam_unix(cron:session): session closed for user root
feb 20 16:56:01 migue postfix/cleanup[9213]: 8EBE150: message-id=<20260220165601.8EBE150@migue>
feb 20 16:56:01 migue postfix/qmgr[2734]: 8EBE150: from=<root@migue>, size=592, nrcpt=1 (queue active)
feb 20 16:56:01 migue postfix/local[9222]: 8EBE150: to=<root@migue>, orig_to=<root>, relay=local, delay=0.03, delays=0.02/0/0/0.01, dsn=2.0.0, status=sent (del
feb 20 16:56:01 migue postfix/qmgr[2734]: 8EBE150: removed
feb 20 16:56:48 migue sudo[189853]:  migue31 : TTY=tty1 ; PWD=/home/migue31 ; USER=root ; COMMAND=/usr/bin/journalctl -xe
feb 20 16:56:48 migue sudo[189853]: pam_unix(sudo:session): session opened for user root(uid=0) by migue31(uid=1000)
lines 3041-3089/3089 (END)
```

Parte 6: Mitigación y Hardening

Eliminar usuario sospechoso

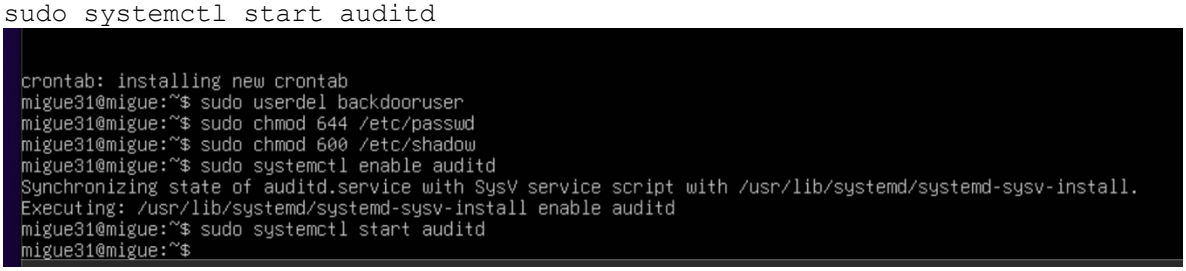
```
sudo userdel backdooruser
```

Revisar permisos críticos

```
sudo chmod 644 /etc/passwd
sudo chmod 600 /etc/shadow
```

Habilitar auditd

```
sudo systemctl enable auditd
sudo systemctl start auditd
```



Recomendaciones adicionales

- Activar firewall (ufw)
- Deshabilitar login root remoto
- Actualizaciones automáticas
- Integridad con AIDE (opcional avanzado)

Parte 7: Reflexión

Responder las siguientes preguntas

1. ¿Por qué los rootkits son difíciles de detectar?

   Porque los rootkits (especialmente los de Kernel) modifican las herramientas que usas para investigar. Si el comando ls está infectado, te ocultará los archivos del propio rootkit.

2. ¿Cuál es la diferencia entre detección en espacio de usuario y kernel?

   reemplazan archivos ejecutables; los de **kernel** modifican el núcleo del sistema operativo para interceptar llamadas al sistema (syscalls), haciéndolos casi invisibles para el SO

3. ¿Por qué muchas veces se recomienda reinstalar el sistema?

   Una vez que el kernel está comprometido, no se puede confiar en ninguna herramienta de limpieza ejecutada desde ese mismo sistema. No hay garantía de haber eliminado cada puerta trasera oculta.

4. ¿Qué controles preventivos hubieran evitado el compromiso?

   Implementar el principio de menor privilegio, usar firewalls (UFW), deshabilitar el acceso root por SSH y mantener el sistema actualizado

   Conclusión

   La práctica demuestra que la detección de rootkits requiere un enfoque multi-herramienta, ya que estas amenazas están diseñadas para evadir controles estándar modificando procesos y archivos del sistema. Mientras que **chkrootkit** y **rkhunter** son efectivos para identificar indicadores de compromiso (IoC) y firmas conocidas, **Lynis** es esencial para establecer medidas de **hardening** preventivo. En definitiva, la seguridad efectiva en Linux no depende solo de la limpieza tras una infección, sino de reducir la superficie de ataque mediante el principio de menor privilegio y el monitoreo constante con herramientas como **auditd**.

Evidencia a Entregar

- Capturas de ejecución de herramientas
- Tabla comparativa de herramientas
- Redacción de Conclusión